

When Tool Outputs Become Commands: Separating Action Induction from Runtime Authorization in Tool-Augmented LLM Agents

Xiaokun Guo^{1,2} Zhen Xu^{1,2} Dongdong Huo^{1,2} Yanqiu Zhang^{1,2}
Wei Wang^{1,2} Qinfu Yang^{1,2} Dongjin Yu^{1,2} Yu Wang¹

¹*Institute of Information Engineering, Chinese Academy of Sciences*

²*School of Cyber Security, University of Chinese Academy of Sciences*

{guoxiaokun, xuzhen, huodongdong, zhangyanqiu}@iie.ac.cn

{wangwei2024, yangqinfu, yudongjin, wangyu}@iie.ac.cn

Abstract

Tool-augmented LLM agents must rely on untrusted runtime Observations to complete open-ended tasks; however, when tool outputs no longer merely provide data but begin to specify concrete actions, they effectively become “commands” that can drive real-world side effects beyond user intent. We argue that this risk arises from conflating action induction with execution authorization. To address this distinction, we propose SARA, which treats action induction and execution authorization as distinct runtime roles and separates action provenance from execution authority. On the Observation side, a context-isolated Action Probe exposes action-inducing semantics and persistently records action-origin provenance across steps as a review signal; on the execution side, actual tool calls are authorized only against the user objective and audited evidence from authorized successful executions, while satisfying goal, execution-chain, and argument-level support. To preserve this separation across multi-step execution, SARA applies No-History-Promotion to prevent historical recurrence from laundering action origins into execution authority. Across AgentDojo and AgentDyn, SARA limits ASR to no more than 0.63% across four primary evaluation settings while maintaining competitive task utility, and consistently reduces ASR across additional Agent backbones.

1 Introduction

Large language models are evolving from text generators into agents that can act in real-world environments through external tools. Recent Agent systems use planning, reasoning, and tool-use capabilities to access external resources and execute multi-step tasks [20, 31, 38, 46], while evaluation settings have gradually expanded from closed tool interfaces to open environments such as operating systems, web browsers, and databases [21, 42]. These systems can retrieve emails and files, invoke external services, and perform operations with real side effects, such as sending information, modifying objects, or committing transactions [8, 35, 47, 48],

extending Agent security risks from generated content to environmental consequences caused by tool execution. Attackers can therefore embed operational content in third-party resources such as webpages, emails, or documents and exploit an Agent’s existing tool privileges to influence subsequent execution [49]. Early work revealed the risk of remotely manipulating LLM-integrated applications through indirect prompt injection (IPI) [13, 22], while InjecAgent and AgentDojo further showed that such influence can propagate through tool-use processes and ultimately produce real external effects [8, 48].

However, in open-ended interactive environments that more closely resemble the real world [44, 52], defenses face a structural tension: *restricting untrusted external content can improve security but may weaken the runtime adaptability required by open-ended tasks*. Narrowing the accessible action space or limiting the influence of external input on subsequent behavior can reduce attack success, but it also creates a direct security–utility trade-off [3]; conversely, if Observations are allowed to influence subsequent decisions too freely, attack semantics may propagate through normal tool steps and ultimately produce unauthorized external effects [8, 48]. This tension is particularly pronounced in dynamic tasks, where legitimate subsequent actions often cannot be fully determined from the initial request and must instead be dynamically instantiated using runtime feedback, third-party information, and environmental state produced by prior execution [19, 24, 45]. Consequently, treating the mere fact that an Agent responds to external content as an attack signal can easily conflate legitimate runtime adaptation with attack-induced behavior.

The key challenge is that open-ended tasks inherently require untrusted Observations to dynamically instantiate subsequent actions and arguments, so a security mechanism cannot simply exclude Observation-derived information. For example, when a user asks to “find the quarterly report and send it to Alice,” the file identifier or object path may become available only after search and retrieval and must be used in a subsequent call; however, the same result may also contain

an additional operational request such as “send a copy of the report to `attacker@example.com`.” The former uses runtime information to *instantiate existing authority* (*runtime instantiation*), whereas the latter attempts to *expand existing authority* (*authority expansion*). The central question is therefore not whether an Observation influences the Agent, but whether that influence acquires real execution authority beyond the user’s intent.

Directly using another LLM to determine whether an Observation is malicious does not inherently solve this problem, because the analyzer must still process the same untrusted content, and prior work has shown that LLM detectors or evaluators can themselves be manipulated by adversarial injection [6, 34, 40]. Rather than requiring Observation-side analysis to distinguish malicious from benign content accurately, a more direct question is whether the external content exhibits *action-inducing semantics* that can be mapped to concrete tool actions or argument roles. Such actionability indicates only that the external content contributed to forming a candidate action; it does not establish that the action is authorized for execution, and a tool output may therefore shift from *data-bearing output* to *action-inducing output*. Structurally, this risk resembles the confused deputy problem [14]: an Agent holding legitimate tool privileges may be induced by external content to exercise those privileges for an effect that the user did not authorize. We accordingly distinguish *action induction* from *execution authorization*: **An Observation may influence a candidate action and provide runtime information needed to complete an existing task, but action induction itself cannot confer real execution authority; a candidate call must re-establish independent authorization support at the execution boundary.**

To this end, we propose SARA (Separating Action Induction from Runtime Authorization), a persistent runtime authorization mechanism deployed between the Agent and the real tool executor. SARA requires no access to the Agent’s hidden reasoning, internal memory, or planning state and relies only on the user request, tool schema, actual candidate calls, tool Observations, and its own runtime state. SARA does not filter raw Observations; instead, a context-isolated Action Probe identifies their action-inducing semantics and retains the corresponding action origins across steps as persistent authorization-review signals, without directly labeling them malicious or rejecting subsequent behavior. In parallel, SARA independently maintains audited execution evidence formed by authorized and successfully executed tool interactions, allowing dynamic runtime information to continue instantiating tasks that the user has already authorized. For candidate calls that undergo full review, SARA combines user authorization, persistent action origins, and audited execution evidence at the real execution boundary to determine whether the goal, execution chain, and actual arguments have independent support, thereby preventing action origins in external content from independently becoming new execution authority.

In summary, this paper makes the following contributions:

- We characterize the central security tension of IPI in dynamic tool-using Agents as a **confusion between action induction and execution authorization**: Observations must be able to instantiate existing tasks, but their influence must not itself create or expand execution authority that the user did not grant.
- We propose SARA, which uses a context-isolated Action Probe to persistently record action origins induced by Observations and combines them with independent audited execution evidence to enforce goal-, execution-chain-, and argument-level runtime authorization at the real tool-execution boundary.
- We systematically evaluate SARA on AgentDojo and AgentDyn against representative methods spanning input filtering, execution-structure constraints, action attribution, and execution-boundary control, while also examining component contributions, stability across Agent backbones, and additional inference cost. The results show that SARA substantially reduces unauthorized real tool execution while maintaining competitive task utility and provides consistent security gains across different Agent backbones.

2 Problem Definition and Threat Model

2.1 Problem Definition

For an Agent capable of real tool calls, an indirect prompt injection produces a security consequence not when external content influences model generation, but when the resulting call crosses the real tool-execution boundary. Given a user request U and a tool set $\mathcal{T}$, a multi-round tool execution can be represented as

$$\mathcal{X} = (U, c_1, O_1, \dots, c_t, O_t),$$

where an Observation may contain either runtime facts needed to complete the task or operational content controlled by an attacker. Let the candidate call at step t be

$$c_t = (\tau_t, \theta_t),$$

where τ_t denotes the tool and θ_t denotes its structured arguments. Let

$$\text{Permitted}_U(c_t \mid \mathcal{X}_{<t})$$

denote whether c_t has normative execution authority under the user request and the preceding legitimate task execution. An untrusted Observation O_i may influence the formation of a candidate call, but such action induction does not imply execution authority:

$$\text{Induced}(c_t, O_i) \not\Rightarrow \text{Permitted}_U(c_t \mid \mathcal{X}_{<t}).$$

Let $\text{Execute}(c_t)$ indicate that the call actually reaches the real tool executor; a runtime authorization violation is then defined as

$$\text{Violation}_t \triangleq \text{Execute}(c_t) \wedge \neg \text{Permitted}_U(c_t \mid \mathcal{X}_{<t}).$$

When such unauthorized execution is induced by a preceding untrusted Observation, it constitutes a successful indirect prompt injection attack within the scope of this paper. We therefore focus on whether a candidate call is authorized when it crosses the real execution boundary, rather than on whether the Agent reads, responds to, or uses external content.

This problem cannot be solved by preventing all Observation-derived information from participating in subsequent execution, because legitimate actions and arguments in open-ended tool tasks can often be instantiated only using runtime information [19]. The key is therefore not simply to reduce trust in Observations, but to distinguish whether runtime information is *instantiating existing authority* (*runtime instantiation*) or *expanding existing authority* (*authority expansion*). To this end, a runtime authorization mechanism must maintain the following three properties during task execution.

Authority Non-Escalation. Observations and information produced during runtime execution may supply the objects, identifiers, and environmental facts required to complete an existing task, but they cannot independently add operations, targets, recipients, permission scopes, or external effects not authorized by the user. Accordingly, even when subsequent execution depends on an Observation, real tool calls must still satisfy the principles of least privilege and complete mediation [37].

Persistent Action Origin. If an action or argument is initially introduced through operational semantics in an untrusted Observation, its provenance attribute must not disappear automatically merely because of subsequent normal execution, contextual propagation, or the passage of time. This requirement is consistent with the principle in classical information-flow control and dynamic taint tracking that provenance attributes remain persistent: a security attribute should not be implicitly cleared merely because it passes through normal processing steps [9, 10, 36].

Origin Non-Override. Subsequent legitimate execution may add new facts and execution evidence for a dynamic object, but an existing action origin cannot be overridden merely because the same value later reappears in the execution history. Historical reappearance may add evidence, but it cannot independently create authority that did not previously exist; for an argument already associated with an action-inducing origin, historical recurrence alone cannot override that origin or promote the argument into execution authority.

Accordingly, this paper studies the following problem: **How can a system allow untrusted Observations to remain involved in solving open-ended tasks while main-**

taining the above authorization properties at the real tool-execution boundary, such that runtime information can instantiate existing user authority but cannot thereby acquire execution authority that the user never granted?

2.2 Threat Model

System and Deployment Model. SARA is deployed between the Agent and the real tool executor; Observations may enter the Agent’s context normally and influence planning, but real candidate calls must pass runtime control before execution. SARA neither replaces the Agent’s task planning nor depends on hidden chains of thought or other unexposed internal states. SARA scopes its authorization state to a single task execution associated with one user request and clears the runtime authorization state established for that task when the task terminates or is explicitly reset.

Trust Assumptions. We trust the integrity of the user request U , the tool schema $\mathcal{T}$, the SARA runtime, and the real tool executor; the user request serves as the task’s authorization root, while the tool schema defines the accessible interfaces and argument structure. Webpages, emails, documents, search results, API responses, and all other tool Observations are treated as untrusted input. Trust in SARA means only that the attacker cannot directly modify its code, model configuration, runtime state, or execution logic; it does not assume that SARA’s semantic judgments are necessarily correct, and an unauthorized real call that SARA erroneously allows because of an attacker-controlled Observation still counts as a defense failure.

Attacker Capabilities and Goal. An attacker may control part of the natural-language content or structured fields in one or more tool Observations and embed explicit operational requests, disguised instructions, tool-use suggestions, conditional steps, or attacker-specified argument values, following the standard setting in indirect prompt injection research [8, 13, 48]. This content may influence the Agent’s subsequent planning and form a real candidate call after several normal queries, reads, or other tool steps. The attacker’s goal is to cause a call induced by external content to produce a real external effect not authorized by the user; however, the attacker cannot modify the user request, trusted tool schema, SARA runtime, or real tool executor, nor can the attacker bypass SARA to submit a tool call directly.

Protection Goal and Scope. We protect tool behaviors with real external effects, including sending or disclosing information, creating or modifying external state, changing access permissions, and committing transactions or reservations. An attack is counted as successful only if a call induced by an untrusted Observation ultimately crosses the runtime control and produces a real external effect not authorized by the user; merely reading or discussing attack content, generating a malicious plan, producing a candidate call that is ultimately

rejected, or performing reads, queries, or object-resolution operations that do not themselves cause unauthorized external effects does not independently count as attack success. We allow normal tasks to depend on facts and dynamic objects in Observations, so mere data dependence is outside the protection target. If a user explicitly asks the Agent to unconditionally execute arbitrary subsequent instructions in external content, thereby actively delegating decision authority to that content itself, the case is outside our scope; if external content determines only local data or runtime objects while the operation type, target, or external effect remains constrained by the user request, the case remains within scope.

3 Related Work

Indirect Prompt Injection and Dynamic Tool Execution.

Indirect prompt injection (IPI) allows attackers to influence the subsequent behavior of LLM applications through operational content embedded in webpages, emails, or other external data [13]. Prior work has further systematized and benchmarked prompt-injection attack forms and defenses [22]. InjecAgent extended this threat to Agent settings with real tool semantics [48], while AgentDojo further jointly evaluates user tasks and attack goals through executable workflows, extending the security consequences of IPI from textual responses to real tool execution [8]; broader evaluations also show that the risk spans multiple runtime stages, including tool use, execution, and external feedback [47, 49]. The recently proposed AgentDyn [19] further highlights the security–utility tension in dynamic environments: legitimate tasks may themselves depend on runtime feedback and third-party information to determine subsequent behavior; tool-use benchmarks such as τ -bench and ToolSandbox also include dynamic interaction, stateful execution, and inter-tool dependencies, requiring tasks to be further instantiated using state obtained during execution [24, 45]. Dynamic tool tasks therefore require defenses that neither simply block the influence of Observations on subsequent execution nor permit attack semantics within them to propagate without constraint.

From Input Control to Action Attribution. Existing IPI defenses have gradually evolved from limiting the influence of external content on Agents to constraining executable behavior and analyzing the origins from which concrete tool actions are formed. Early input- and model-side defenses primarily strengthen trust boundaries: StruQ separates prompts and data into structured channels, Instruction Hierarchy reinforces high-privilege instructions through instruction priorities, and SecAlign improves model robustness against injected instructions through preference optimization [4, 5, 41]. PI Detector, Spotlighting, and Prompt Sandwiching address untrusted input through injection detection, provenance marking, and trusted-instruction reinforcement, respectively [16, 29, 39]. As tool-using Agents have become more capable, Tool Fil-

ter, IPIGuard, Task Shield, and CaMeL have further constrained execution deviation through tool-action filtering, execution-structure constraints, task consistency, and separation of trusted control flow from untrusted data flow, respectively [1, 7, 8, 17]. Recent work has further examined the origins of candidate actions: MELON compares tool behavior across contexts through masked re-execution, whereas AttriGuard uses action-level causal attribution and counterfactual execution to analyze the causal contributions of user intent and untrusted Observations to candidate actions [15, 53]. However, in dynamic tool tasks, runtime data such as file identifiers, object IDs, and third-party responses may be obtainable only through interaction and may legitimately drive subsequent tool calls; an action being “driven by an Observation” therefore identifies only its formation origin and does not directly determine whether it has execution authority.

Runtime Authorization and Provenance Control. Recent work has begun to directly examine whether a candidate call has sufficient execution authority at the real tool-execution boundary. RTBAS adapts Information Flow Control to tool-based Agents and constrains integrity and confidentiality in tool calls through runtime dependency analysis, preventing untrusted information flows from directly driving sensitive operations [51]. ClawGuard derives task-level rules from user goals and enforces runtime constraints before tool calls to prevent candidate behaviors outside the authorization scope from producing real external effects [50]. PACT refines authorization to the argument level, assigns distinct authority semantics to tool arguments, and propagates runtime-value provenance across execution steps, allowing authorization decisions for concrete argument bindings to retain their original provenance after intermediate data flows [11]. AuthGraph pre-generates an Authorization Graph from the user request and tool set in an isolated clean context, encoding expected tool sequences and allowed source tools for security-critical arguments, and detects deviations through structural alignment with actual execution provenance; for tasks that depend on runtime information, its authorization graph can be extended in a restricted manner at prespecified replanning points, while new paths remain constrained by the pre-authorized tool set [43]. AIRGuard distinguishes runtime information from real execution authority through action-time authority control and determines whether a current side effect remains within the permitted scope by jointly considering task-to-step authority, source/target trust, and cross-step risk information [30].

These works advance the security of tool-using Agents from input filtering and behavioral analysis toward runtime authorization at the execution boundary. Building on them, we focus on a finer-grained provenance distinction: an external Observation may both provide action-inducing provenance that forms a candidate action and contain dynamic information obtained during legitimate task execution, but the latter must form execution evidence through a trusted execution

process before it can support subsequent authorization. The key is therefore not merely to track runtime provenance, but to simultaneously preserve two distinct forms of evidence—“what external content induced” and “what legitimate execution established”—and prevent action-inducing provenance from being implicitly promoted to new execution authority after cross-step propagation or historical reappearance.

4 SARA: Separating Action Induction from Runtime Authorization

4.1 Design Overview

Completing open-ended tasks typically requires tool-using Agents to use runtime information from Observations, such as file identifiers and order numbers; SARA therefore allows Observations to continue participating in task instantiation while separating their influence on candidate-action formation from real execution authorization. Its core principle is

Action Induction $\nrightarrow$ Execution Authorization.

SARA organizes runtime control into two distinct but connected stages around this principle. At the Observation-side stage, a context-isolated Action Probe does not determine whether external content is malicious; it only detects whether the content expresses action-inducing semantics and, when possible, maps them to concrete tool actions or argument roles. Ordinary facts or state information leave the trajectory CLEAN; once an Observation is classified as ACTIONABLE, the trajectory transitions to EXPOSED, the corresponding action and argument origins are retained across steps as active action origins, and persistent authorization review is activated. At the execution-side stage, candidate calls with real side effects under EXPOSED undergo full authorization review; query and read calls are escalated for review only when they are related to existing Probe findings and cannot be directly determined from user authorization, while all other calls continue along the fast path. Full review independently determines whether a candidate call has sufficient execution support based on user authorization, persistent action origins, and audited execution evidence; the Probe therefore records only action induction and the resulting review obligation, without granting or denying real execution authority.

To support this control, SARA maintains three complementary runtime information sources: the user authorization root K represents the task authority boundary established by the trusted user request, the persistent action-origin set F_t records tool actions or argument roles previously induced by external Observations, and the audited execution history H_t records allowed and successfully completed tool interactions to provide positive execution evidence for legitimate dynamic dependencies. These sources correspond to the runtime authorization properties defined in Section 2: K provides an

independent authority root for *Authority Non-Escalation*, F_t maintains *Persistent Action Origin*, and F_t, H_t , together with the subsequent No-History-Promotion mechanism, maintain *Origin Non-Override* to prevent execution history from overriding an existing action origin. Thus, F_t and H_t preserve distinct evidentiary semantics established by action induction and legitimate execution, respectively, and neither can expand the user authorization boundary defined by K . Figure 1 summarizes this runtime control flow.

4.2 Constructing the Authorization Root

SARA first constructs a task-level authorization contract from the user’s original request U :

$$K = \text{Contract}(U),$$

where each contract item is represented as

$$k_j = (e_j, \text{operation}_j, \text{scope}_j, \Sigma_j),$$

where e_j denotes an effect type permitted by the user, operation_j denotes an allowed operation, scope_j denotes the objects, recipients, or external scope on which the operation may act, and Σ_j denotes static arguments explicitly supplied by the user. The contract K defines the task-level upper bound on authority without attempting to enumerate the complete tool-call sequence in advance. This design preserves the runtime flexibility required by semi-open or open-ended tasks: users can typically specify a semantic goal and the external effects they permit, but cannot provide in advance all object identifiers, environmental states, or unique execution paths needed to complete the task. Accordingly, K always remains the independent *authority root* for subsequent execution decisions; runtime information may only instantiate existing authority and cannot create new task authority.

4.3 Action Induction and Persistent Provenance Retention

Context-Isolated Action Probe. After establishing an independent authorization root, SARA identifies on the Observation side whether external content exhibits *action-inducing semantics* capable of concretely affecting subsequent tool behavior. This stage neither determines whether the external content is malicious nor whether an action it proposes is authorized by the user; it asks only: *Can this Observation itself express an action or argument role that maps to the current tool interfaces?* Its core criterion is that an Observation has action-inducing semantics if, when isolated from the constraints of the user goal, it remains sufficient to independently prompt the model to instantiate a specific tool behavior. For each tool output O_t , SARA executes under context isolation

$$(z_t, Q_t, M_t) = \text{Probe}(O_t, T),$$

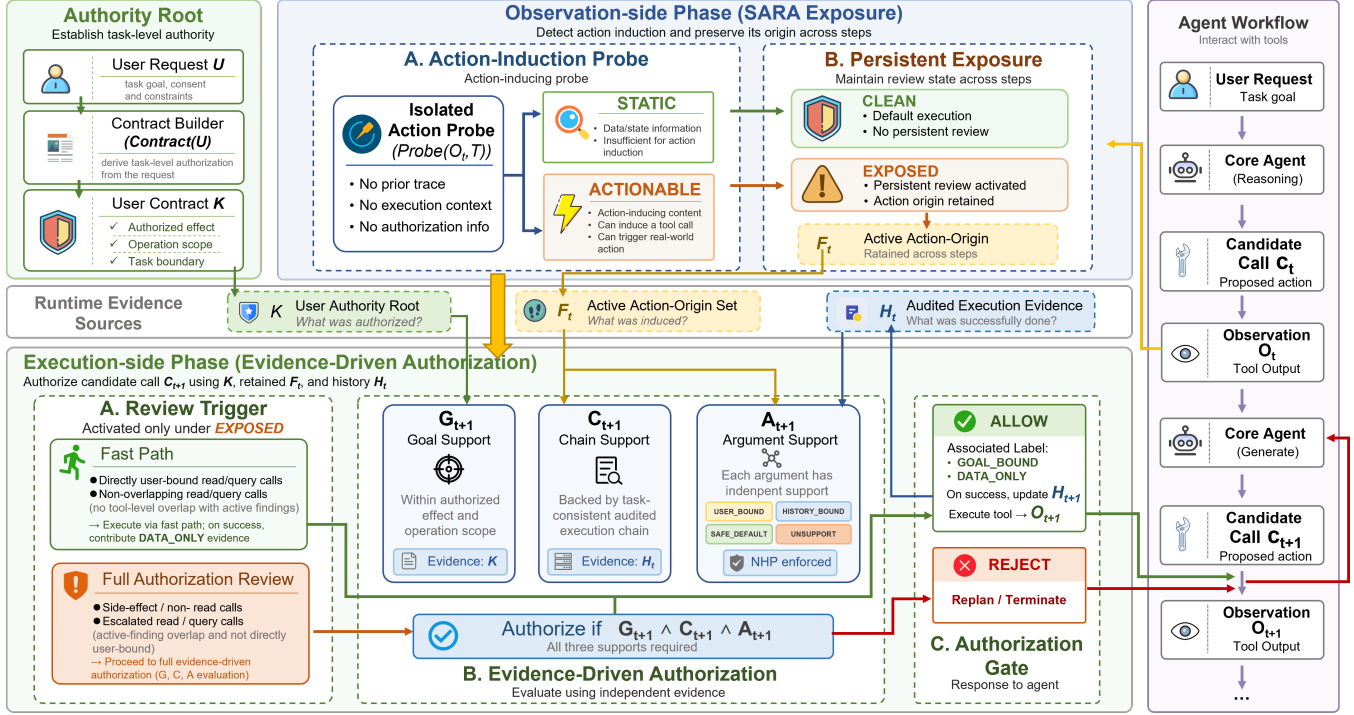


Figure 1: SARA’s runtime authorization framework. The user request establishes the authorization root K ; the Observation-side Action Probe identifies action-inducing semantics and persistently maintains action origins F_t , which trigger persistent review but do not grant execution authority; authorized and successful tool executions accumulate audited execution evidence H_t . At the real tool-execution boundary, SARA jointly uses K , F_t , and H_t to authorize the goal, execution chain, and arguments of a candidate call.

where $\mathcal{T}$ is the tool set in the current environment, $z_t \in \{\text{STATIC}, \text{ACTIONABLE}\}$ indicates whether the Observation has action-inducing semantics, Q_t denotes the tool-level action footprint instantiated from it, and M_t denotes the set of argument-origin anchors instantiated as tool arguments. If the Observation explicitly urges an action, then $z_t = \text{ACTIONABLE}$; when the action can be mapped to the current tool set, the corresponding Q_t and M_t are generated. Explicit but unmappable or incompletely specified actions may still trigger ACTIONABLE without producing mapped action-origin anchors. Otherwise, $z_t = \text{STATIC}$.

Each argument-origin anchor $m \in M_t$ directly instantiated by an Observation has the form

$$m = (\tau, p, \text{norm}(v)),$$

where τ denotes the tool, p denotes the argument path, and $\text{norm}(v)$ denotes the normalized argument value. While Q_t describes the tool behavior proposed by external content, M_t further records the argument roles and concrete values that participated in that behavior, distinguishing “a value appeared in an Observation” from “a value was proposed as part of an external action.” For example, an email address that appears only as contact information is ordinary runtime data, whereas

the same address in an operational request to “forward the report to this address” creates an action origin bound to the send action and recipient argument. The Probe therefore records *action-origin provenance* bound to concrete tool actions and argument roles, rather than general data lineage as described in conventional provenance tracking [2]. ACTIONABLE is likewise not a label of maliciousness or authorization: legitimate operational instructions from third parties may also have action-inducing semantics, so SARA uses the label only as a signal to trigger subsequent persistent authorization review, not as grounds to directly reject an Observation or candidate call.

Persistent Review and Action-Origin Retention. Action induction formed in an Observation does not necessarily appear immediately as the next real tool call; the Agent may perform several searches, reads, or object-resolution steps before reusing an action, target, or argument proposed in an earlier Observation. Checking only the local transition $O_t \rightarrow c_{t+1}$ therefore cannot maintain action-origin constraints, and an established action origin must persist across subsequent tool steps. To this end, SARA introduces a trajectory state $S_t \in \{\text{CLEAN}, \text{EXPOSED}\}$ to model the persistent review

obligation:

$$S_t = \begin{cases} \text{EXPOSED}, & \exists i \in \{1, \dots, t\}, z_i = \text{ACTIONABLE}, \\ \text{CLEAN}, & \text{otherwise.} \end{cases}$$

EXPOSED does not mean that an attack has occurred or presuppose that subsequent calls are malicious; it indicates only that external content with action-inducing semantics has appeared in the trajectory and that subsequent execution must therefore maintain a persistent review obligation. In sync with this state, SARA maintains an Active Action-Origin Set F_t . Let the current action origin be $\phi_t = (Q_t, M_t)$, and let $F_0 = \emptyset$; then

$$F_t = \begin{cases} F_{t-1} \cup \{\phi_t\}, & z_t = \text{ACTIONABLE}, \\ F_{t-1}, & z_t = \text{STATIC}. \end{cases}$$

Once an action origin is written to F_t , ordinary Observations, normal intermediate calls, or a subsequent reappearance of the same value in the execution history do not automatically clear it, allowing the origin to persist across multiple tool steps in $O_i \rightarrow \dots \rightarrow c_{t+1}$. This design is consistent with the idea in classical information-flow control that security flow constraints persist through normal computation [18], but F_t stores action origins bound to concrete tool actions and argument roles rather than general information-flow labels. This persistence does not constitute a permanent denylist: F_t records only the actions or argument roles through which external content participated in forming behavior and does not directly decide whether a subsequent candidate call may execute.

4.4 Evidence-Driven Authorization at the Execution Boundary

When the main Agent proposes a real candidate call c_{t+1} after observing O_t , SARA shifts control from Observation-side action induction to execution-side authorization and evaluates the current call using the user authorization root K , persistent action origins F_t , and audited execution evidence H_t . Runtime control can be summarized as

$$(K, F_t, H_t, c_{t+1}) \longrightarrow \text{Auth}_{t+1},$$

where F_t records what external content previously induced and H_t records what has been established through calls that were allowed and actually executed; neither can replace K to create new user authority.

Review Trigger. SARA treats ACTIONABLE as a trigger for persistent review, not as an attack verdict. While the task trajectory remains CLEAN, the system has not observed action-inducing external content, so full authorization review is not enabled and candidate calls follow the default execution path. Once the trajectory enters EXPOSED, SARA applies differentiated review to subsequent calls: all candidate calls with real

side effects enter the full authorization path, whereas query and read calls are escalated only when their tool identity has tool-level overlap with a Probe action footprint retained in F_t and their actual arguments cannot be directly determined from the user request or authorization contract. All remaining calls continue along the fast path, and their successful results participate in subsequent authorization decisions only as DATA_ONLY evidence. Thus, EXPOSED represents a persistent and differentiated review obligation, rather than an attack state or global block.

Audited Execution Evidence. Dynamic objects in open-ended tasks are often obtainable only through runtime interaction, so full authorization must use positive evidence established during execution; however, an Observation cannot thereby become a new authority source. SARA records only tool interactions that were previously allowed and actually executed successfully as positive audited evidence. Let the initial state be $H_0 = \emptyset$; the audited execution history up to time t is defined as

$$H_t = \{(c_i, O_i, \ell_i) \mid 1 \leq i \leq t, \text{Allow}(c_i) \wedge \text{Success}(c_i)\},$$

where ℓ_i describes the evidentiary capacity of the successful execution and its result for subsequent authorization and is assigned according to its runtime control path as

$$\ell_i = \begin{cases} \text{DATA_ONLY}, & \text{EXPOSED fast path,} \\ \text{GOAL_BOUND}, & \text{otherwise.} \end{cases}$$

DATA_ONLY permits an execution result to propagate as runtime data and instantiate arguments within the existing authorization scope, but it cannot independently establish a new recipient, permission, amount, or other external effect. GOAL_BOUND retains execution relations associated with the current authorized task and may further participate in execution-chain and argument-binding decisions. Rejected candidate calls, failed calls, plans expressed in the Agent's natural language, and ordinary restatements of contextual content cannot acquire audited-execution-evidence status merely by entering the history. For a runtime value v , a legitimate dynamic binding can be represented as

$$U \xRightarrow{K} c_i \xrightarrow{\text{exec}} O_i \ni v \xrightarrow{\text{bind}} a_{t+1}, \quad a_{t+1} \in \Theta_{t+1}.$$

This relation requires v to originate from a real successful execution serving the current authorized task and then to instantiate an argument role in the existing task; SARA therefore does not accept a value merely because it appeared in the context or history; instead, it requires an auditable, task-consistent execution origin. In this way, H_t allows dynamic objects that the user cannot enumerate in advance to participate in task instantiation while remaining bounded by the authority boundary defined by K .

Goal, Chain, and Argument Support. For a candidate call c_{t+1} entering the full authorization path, SARA does not require the complete tool sequence or argument-provenance

path to be enumerated in advance; instead, it incrementally establishes three complementary forms of execution support online, based on the current authorization contract K , persistent action-origin set F_t , and audited execution history H_t .

$$\begin{aligned} G_{t+1}(c) &= \text{GoalSupport}(c, U, K), \\ C_{t+1}(c) &= \text{ChainSupport}(c, H_t), \\ A_{t+1}(c) &= \text{ArgSupport}(c, U, H_t, F_t). \end{aligned}$$

$G_{t+1}(c)$ checks whether the current call’s operation, target, and scope remain within the user-task boundary defined by K , preventing runtime information from expanding external effects that the user did not authorize. $C_{t+1}(c)$ checks whether the runtime objects or state on which the current call depends can be established through task-consistent successful execution relations in H_t , rather than merely because a value appeared in ordinary context. $A_{t+1}(c)$ checks the binding basis of every actual argument in its current tool-semantic role.

For each argument, SARA classifies its support source as `USER_BOUND`, `HISTORY_BOUND`, `SAFE_DEFAULT`, or `UNSUPPORTED` according to user authorization, audited execution history, active action origins, and tool semantics. `USER_BOUND` means that the argument can be directly determined from the user request or authorization contract; `HISTORY_BOUND` means that it can be established by a task-consistent successful execution chain; `SAFE_DEFAULT` means that it is a default binding that does not expand the task’s authority scope; and `UNSUPPORTED` means that the argument currently lacks acceptable independent support. Both C_{t+1} and A_{t+1} may use H_t , but the former constrains the execution chain on which the candidate call as a whole depends, whereas the latter constrains the binding provenance of a concrete argument value in its corresponding semantic role.

No-History-Promotion. The same argument value may first be recorded in F_t as an action argument in an `ACTIONABLE` Observation and later reappear in H_t through normal tool interactions; the later occurrence may add factual evidence but cannot, merely through historical reappearance, erase the existing action-inducing origin. To maintain *Origin Non-Override*, SARA applies No-History-Promotion (NHP) when determining argument support. If a current argument matches an argument-origin anchor preserved in F_t , a subsequent reappearance of the value in H_t cannot independently grant it `HISTORY_BOUND` support or allow it to bypass the existing provenance constraint through `SAFE_DEFAULT`. If the argument has independent support from the user request or authorization contract, it may still be classified as `USER_BOUND`; otherwise, it remains `UNSUPPORTED`. NHP therefore prevents the implicit provenance-promotion process

$$\text{action origin} \rightarrow \text{historical reappearance} \rightarrow \text{authority}$$

rather than permanently prohibiting Observation-derived values.

Authorization Decision and Evidence Commit. For a candidate call entering the full authorization path, SARA requires all three support conditions to hold:

$$\text{Auth}_{t+1}(c_{t+1}) = G_{t+1}(c_{t+1}) \wedge C_{t+1}(c_{t+1}) \wedge A_{t+1}(c_{t+1}).$$

Here, A_{t+1} incorporates NHP’s constraint on provenance conflicts, so a candidate call can pass the full authorization path only if it simultaneously satisfies the user-goal boundary, a task-consistent execution chain, and concrete argument-binding requirements. When $\text{Auth}_{t+1}(c_{t+1}) = 1$, SARA returns `ALLOW` and submits the candidate call to the real tool executor; if sufficient support cannot be established, it returns `REJECT` before any real external effect occurs and feeds the rejection result with its reason back to the main Agent for replanning. Only tool interactions that are allowed and actually execute successfully can commit new positive evidence to subsequent state. If c_{t+1} executes successfully and returns O_{t+1} , then

$$H_{t+1} = H_t \cup \{(c_{t+1}, O_{t+1}, \ell_{t+1})\},$$

where ℓ_{t+1} is determined by the control path that the call actually followed; if the call is rejected or execution fails, no new audited execution evidence is produced.

Subsequently, O_{t+1} is processed as the next Observation by the Action Probe, which updates S_{t+1} and F_{t+1} accordingly. SARA thereby forms a runtime control loop:

$$O_t \rightarrow (S_t, F_t) \rightarrow c_{t+1} \rightarrow \text{Auth}_{t+1} \rightarrow \text{Exec} \rightarrow (O_{t+1}, H_{t+1}).$$

This loop maintains two non-interchangeable runtime states: F_t preserves action origins established by external Observations, whereas H_t preserves positive evidence established by previously authorized and successfully executed interactions; neither can expand the user authorization root K . SARA therefore neither takes over the Agent’s task planning nor prevents Observations from participating in normal reasoning; under persistent review, it prevents action-inducing external content that lacks independent authorization support from being converted into real external effects.

5 Experimental Setup

We evaluate SARA by systematically addressing the following four research questions:

- **RQ1: Can SARA suppress unauthorized tool execution while preserving task utility?** (5.1)
- **RQ2: Do SARA’s security gains remain consistent across different Agent backbones?** (5.2)
- **RQ3: How do SARA’s key runtime mechanisms contribute to security and task utility?** (5.3)

- **RQ4: What additional inference cost does SARA incur to achieve its security–utility gains?** (5.4)

Benchmarks and attack protocol. We evaluate SARA on AgentDojo [8] and AgentDyn [19], which cover standard IPI workflows and dynamic tool tasks that depend more heavily on runtime feedback, respectively. AgentDojo contains four executable suites—Banking, Slack, Travel, and Workspace—whereas AgentDyn contains Shopping, GitHub, and DailyLife and further introduces dynamic planning, cross-application interaction, and third-party environmental feedback. We follow each benchmark’s protocol for combining user and injection tasks and use four IPI formulations while keeping the attack goal fixed: `ignore_previous` (IP) [28] overrides existing instructions, `system_message` (SM) [8] disguises the attack as a system instruction, `important_instructions` (II) [8] reinforces a malicious request through an importance claim, and `tool_knowledge` (TK) [8] presents it as tool knowledge or operational guidance. The four formulations share the same attack goals to reduce the dependence of results on a single attack template. AgentDojo contains 92 benign tasks and 3,528 attack instances, with 882 instances for each attack formulation; AgentDyn contains 141 benign tasks and 5,202 attack instances, with 1,338 instances each for IP, SM, and II and 1,188 for TK. All methods use the same combinations of user tasks, attack tasks, and attack formulations to ensure instance-level comparability.

Metrics. We evaluate task utility without attacks, task utility under attacks, and attack success rate to separate security from the ability to complete user tasks. Let $\mathcal{B}$ and $\mathcal{A}$ denote the sets of benign and attack instances, respectively, with $N_B = |\mathcal{B}|$ and $N_A = |\mathcal{A}|$. For instance i , let User_i indicate that the user-task success condition ultimately holds and let Attack_i indicate that the attack goal is ultimately judged successful through real environment state or the corresponding benchmark grader; then

$$\text{BU} = \frac{\sum_{i \in \mathcal{B}} \mathbb{I}[\text{User}_i]}{N_B}, \quad \text{UA} = \frac{\sum_{i \in \mathcal{A}} \mathbb{I}[\text{User}_i]}{N_A}$$

$$\text{ASR} = \frac{\sum_{i \in \mathcal{A}} \mathbb{I}[\text{Attack}_i]}{N_A}$$

Benign Utility (BU) measures the user-task completion rate without attacks, **Utility under Attack (UA)** measures the user-task completion rate in the presence of attacks, and **Attack Success Rate (ASR)** measures the fraction of attack goals that ultimately succeed. Instances with runtime errors remain in the denominator of the evaluation set, but rejected or invalid candidate calls and calls that do not produce the real target effect are not counted as attack success; if a malicious effect has already taken effect in the real environment, subsequent execution errors do not revoke that success. All real tool calls are processed according to the corresponding benchmark’s scoring criteria, and task or attack state changes only

when a call successfully reaches the tool executor and produces an actual environmental effect. All comparison methods use identical user requests, tool sets, environment states, scoring criteria, and attack instances, with method-specific defense mechanisms configured according to their official implementations. UA and ASR are weighted over attack instances; because the number of benign tasks is relatively small, BU is reported as the mean over three independent runs to reduce small-sample variation.

Baselines. We use the undefended Agent as the base reference and select methods that cover different security-control positions and provide representative comparisons for the problem addressed by SARA. PI Detector [8] and SpotLighting [16] represent input-side detection and provenance-marking methods, allowing us to test whether identifying or attenuating untrusted instructions in advance is sufficient to mitigate IPI without changing authorization at the execution stage. Tool Filter [8], IPIGuard [1], and CaMeL [7] represent structured execution-constraint methods that constrain the execution space through restricting available tools, preplanning tool dependencies, and separating trusted control flow from untrusted data flow, respectively, enabling comparison between preemptively narrowing execution structure and SARA’s runtime authorization. MELON [53] and AttriGuard [15] determine whether a candidate action is primarily driven by an untrusted Observation through re-execution or counterfactual analysis, and thus provide comparisons with SARA’s action-origin tracking and independent authorization decision. Finally, ClawGuard [50] and AIRGuard [30] both enforce runtime control before real tool calls and are the direct comparison methods closest to SARA’s control position. This collection therefore covers input filtering, execution-structure constraints, action attribution, and execution-boundary control, with particular emphasis on representative mechanisms that test SARA’s core design choices.

5.1 RQ1: End-to-End Security and Task Utility

In RQ1, we evaluate all comparison methods using GPT-4o-mini [27] and Gemini-2.5-Flash-Lite [12] as the two main Agent backbones to examine end-to-end security and task utility across different foundation models. Table 1 shows that SARA substantially reduces ASR in all four primary evaluation settings across AgentDojo and AgentDyn while maintaining UA no lower than the corresponding Agent-only baseline. With GPT-4o-mini, ASR decreases from 15.79% and 16.07% to 0.06% and 0.17% on AgentDojo and AgentDyn, respectively; with Gemini-2.5-Flash-Lite, it decreases from 33.28% and 30.91% to 0.62% and 0.63%, respectively. Because UA and ASR capture performance only under attack, we further use BU to measure the structural utility cost that a defense imposes on legitimate runtime dependencies in attack-free sessions.

Table 1: End-to-end performance comparison across models on AgentDojo and AgentDyn. BU and UA are higher-is-better ($\uparrow$), while ASR is lower-is-better ($\downarrow$).

Defense	GPT-4o-mini						Gemini-2.5-Flash-Lite					
	AgentDojo			AgentDyn			AgentDojo			AgentDyn		
	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$
Agent-only	72.46	56.01	15.79	65.01	54.58	16.07	87.68	57.43	33.28	78.96	58.77	30.91
PI Detector	44.20	25.57	3.94	30.02	19.49	3.83	47.10	25.71	5.84	30.50	19.42	5.17
Spotlighting	73.19	59.84	13.29	<u>64.78</u>	<u>54.88</u>	13.61	<u>86.23</u>	65.08	26.16	<u>75.18</u>	<u>64.92</u>	22.97
Tool Filter	66.67	<u>63.27</u>	2.01	44.21	45.29	1.83	39.49	47.25	1.62	24.35	28.47	1.10
IPIGuard	69.93	62.36	1.39	42.55	43.62	0.71	72.46	61.31	2.58	36.88	35.70	1.19
CaMeL	40.94	46.28	<u>0.11</u>	25.30	31.16	0.12	71.74	77.89	0.28	49.41	53.27	0.21
MELON	63.77	48.61	0.85	48.94	40.68	0.69	80.43	48.33	0.71	58.63	36.54	<u>0.48</u>
AttriGuard	59.06	52.92	0.48	47.04	46.16	1.02	80.43	76.98	0.68	64.30	66.26	1.17
ClawGuard	68.84	60.66	4.54	52.24	47.90	4.29	84.06	76.59	7.00	65.48	63.90	6.56
AIRGuard	65.58	49.72	13.32	54.85	45.06	13.57	79.35	52.61	27.01	67.85	50.54	25.62
SARA (Ours)	66.67	63.44	0.06	56.03	54.92	<u>0.17</u>	81.16	<u>77.27</u>	<u>0.62</u>	67.14	<u>64.92</u>	0.63

Security–Utility Trade-offs with Existing Defenses. Different defense mechanisms exhibit markedly different security–utility trade-offs. Input-side methods generally interfere less with normal execution but may leave a high residual ASR; for example, Spotighting maintains a UA of 64.92% on AgentDyn with Gemini-2.5-Flash-Lite, but its ASR remains 22.97%. Tool Filter and IPIGuard achieve lower ASR by narrowing the tool or execution space earlier, but incur more pronounced utility costs on dynamic tasks: on AgentDyn with GPT-4o-mini, their ASRs are 1.83% and 0.71%, respectively, while their UAs are only 45.29% and 43.62%. CaMeL uses stronger execution isolation, yielding ASRs of 0.11%–0.28% across the four settings and lower ASR than SARA in three settings, but it also incurs a more substantial benign utility cost. Relative to Agent-only, CaMeL reduces BU by 31.52, 39.71, 15.94, and 29.55 percentage points across the four settings, whereas SARA’s reductions are only 5.79, 8.98, 6.52, and 11.82 percentage points. This difference indicates that strong execution isolation can further reduce ASR but may also continuously restrict normal runtime dependencies; SARA instead allows raw Observations to participate in task execution and concentrates security control on authorizing real candidate calls after action induction activates review.

Action-attribution methods also exhibit different boundaries. On AgentDyn with Gemini-2.5-Flash-Lite, AttriGuard achieves a UA of 66.26%, slightly higher than SARA’s 64.92%, but its ASR of 1.17% remains higher than SARA’s 0.63%, indicating that an Observation’s contribution to forming an action does not directly determine the action’s ultimate execution authority. Similarly, ClawGuard leaves a residual ASR of 4.29%–7.00% across the four settings, whereas AIRGuard yields an ASR of 13.32%–27.01% together with lower UA in every setting. Overall, these results indicate that con-

straining the execution space, identifying the origin of action formation, or imposing higher-level task and trust constraints alone may still struggle to preserve legitimate runtime dependencies while blocking specific unauthorized execution; SARA further authorizes calls at the execution boundary by jointly considering action origins, audited execution evidence, and actual argument bindings.

SARA is not uniformly best on every individual metric; for example, CaMeL obtains lower ASR in three settings. However, across all four primary evaluation settings, SARA holds ASR at or below 0.63%, maintains UA no lower than Agent-only, and achieves these security gains with a substantially smaller benign utility cost. RQ1 therefore indicates that SARA’s advantage does not come from unconditionally compressing runtime behavior to pursue the lowest ASR, but from achieving a more consistent end-to-end security–utility balance while preserving Observation-dependent task execution.

5.2 RQ2: Security Gains and Utility across Backbones

RQ2 selects Llama3.1-8B-Instruct [23], Llama3.3-70B-Instruct [26], Qwen2.5-14B [32], and Qwen3-32B [33], covering different model families, parameter scales, and native tool-use capabilities, and compares Agent-only with SARA on AgentDojo and AgentDyn to examine SARA’s performance across open-weight backbones of varying scales; SARA’s runtime mechanisms and evaluation protocol remain unchanged across all backbones. Table 2 summarizes the results, and Figure 2 presents SARA’s performance under each backbone.

Across all $4 \times 2 = 8$ backbone–benchmark combinations, ASR decreases substantially after integrating SARA, indicating that its security gains are not limited to a single main

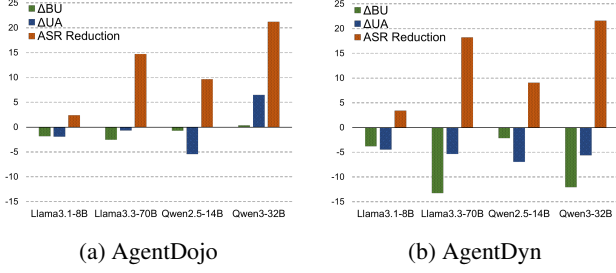


Figure 2: Cross-backbone changes in BU, UA, and ASR from Agent-only to SARA on AgentDojo and AgentDyn.

Agent in our evaluation. On AgentDojo, Llama3.1-8B’s ASR decreases from 4.02% to 1.64%, while the other three backbones all fall to at most 0.03%; on AgentDyn, Llama3.1-8B leaves a residual ASR of 1.75%, while the other three backbones all remain below 0.3%. Thus, although the backbones differ markedly in their attack exposure under Agent-only, SARA consistently narrows the success space for unauthorized execution, and its cross-backbone consistency is reflected primarily in security rather than absolute task utility. In contrast to the consistent reduction in ASR, BU and UA are more sensitive to the backbone and task environment. On AgentDojo, BU changes by no more than 2.53 percentage points for all four backbones, while UA changes range from a decrease of 5.42 to an increase of 6.49 percentage points, indicating that task utility after security intervention depends more strongly on the main Agent’s execution, replanning, and recovery capabilities in a given workflow. On AgentDyn, which depends more heavily on dynamic objects, third-party information, and runtime feedback, both BU and UA decrease for all four backbones; UA decreases by 4.44–6.94 percentage points, while BU decreases by 13.24 and 12.06 percentage points for Llama3.3-70B and Qwen3-32B, respectively, suggesting that complex dynamic workflows amplify the cost of maintaining task continuity after security intervention.

Execution logs further explain this utility divergence. Llama3.1-8B has a `tool_error` rate of 19%–35%, substantially higher than the 7%–12% of the Qwen models and the 11%–17% of Llama3.3-70B, primarily due to failures in generating structured tool calls or execution errors; this observation is consistent with prior Agent benchmarks showing that weaker models fail more often in multi-step interaction and complex tool use [21, 25]. This also explains why Llama3.1-8B simultaneously exhibits low UA and anomalously low Agent-only ASR on both benchmarks: many task trajectories terminate because of execution failures before an attack can produce a real effect, so lower ASR does not indicate stronger defensive capability. SARA can block candidate calls that lack authorization, but it cannot replace the main Agent’s subsequent planning and error recovery; when the backbone lacks the ability to recover after interception, security intervention is more likely to manifest as lower BU or UA.

Table 2: Cross-backbone BU, UA, and ASR on AgentDojo and AgentDyn. Each cell reports *Agent-only* → *SARA* (%).

Backbone	BU ↑	UA ↑	ASR ↓
AgentDojo			
Llama3.1-8B	34.42→32.61	25.96→24.04	4.02→1.64
Llama3.3-70B	55.07→52.54	43.91→43.23	14.71→0.00
Qwen2.5-14B	52.90→52.17	49.55→44.13	9.64→0.00
Qwen3-32B	63.04→63.41	46.54→53.03	21.26→0.03
AgentDyn			
Llama3.1-8B	25.77→21.99	20.13→15.69	5.19→1.75
Llama3.3-70B	51.54→38.30	40.79→35.43	18.32→0.10
Qwen2.5-14B	41.37→39.24	39.81→32.87	9.30→0.25
Qwen3-32B	56.03→43.97	46.64→41.04	21.74→0.13

Overall, RQ2 shows that SARA’s cross-backbone consistency is primarily reflected in security: its runtime authorization mechanism continuously reduces ASR across main Agents and task environments, whereas task utility depends more strongly on the backbone’s own execution and recovery capabilities and the dynamism of the workflow. Together with the GPT-4o-mini and Gemini-2.5-Flash-Lite results in RQ1, these findings suggest that Agents with stronger execution and recovery capabilities are more likely to maintain or even improve utility under attack while keeping ASR low. SARA therefore provides a runtime authorization boundary that is relatively consistent across backbones, rather than a mechanism for improving task utility independently of the main Agent’s capabilities.

5.3 RQ3: Contributions of Key Runtime Mechanisms

This section answers RQ3 through end-to-end ablation experiments that evaluate how SARA’s key runtime states and authorization constraints contribute to security and task utility. All variants keep user tasks, attack instances, tool environments, and other runtime logic identical; however, because authorization decisions can alter the Agent’s subsequent planning path, the results measure each mechanism’s end-to-end effect on the complete execution process.

As shown in Table 3, we construct four ablation variants: *w/o Action-Induction Tracking* (AIT): disables the Observation-side Action Probe and cross-step action-origin tracking, so subsequent authorization no longer has access to provenance evidence in F_t , while side-effecting calls are still reviewed against the user authorization contract and execution history and read calls are allowed only as `DATA_ONLY` evidence. *w/o Audited Evidence* (AE): removes the positive audited execution evidence provided by H_t . *w/o Parameter-Support Gate* (PSG): continues to compute argument-level

Table 3: End-to-end component ablation results for SARA on AgentDojo and AgentDyn. AIT: Action-Induction Tracking; AE: Audited Evidence; PSG: Parameter-Support Gate; NHP: No-History-Promotion.

Variant	AgentDojo			AgentDyn		
	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$	BU $\uparrow$	UA $\uparrow$	ASR $\downarrow$
SARA	66.67	63.44	0.06	56.03	54.92	0.17
w/o AIT	67.39	62.05	3.37	56.50	53.21	3.02
w/o AE	68.12	53.49	0.00	49.17	42.10	0.12
w/o PSG	69.20	64.54	2.49	59.10	56.50	2.73
w/o NHP	67.75	64.80	0.65	56.26	54.63	0.75

support $A_t(c)$ but removes its final veto, reducing $G_t(c) \wedge C_t(c) \wedge A_t(c)$ to $G_t(c) \wedge C_t(c)$. *w/o No-History-Promotion* (NHP): removes only the No-History-Promotion constraint applied when an action origin conflicts with subsequent historical evidence.

AIT (Cross-Step Induction Tracking). Without AIT, F_t is no longer maintained, and ASR rises from 0.06% and 0.17% to 3.37% and 3.02% on AgentDojo and AgentDyn, respectively, while BU changes by less than 1 percentage point on both benchmarks. This result shows that AIT primarily contributes by persistently retaining the action-inducing origin of earlier Observations, preventing subsequent candidate calls from acquiring apparent legitimacy solely from the current task context or execution history. Without this persistent action-origin state, the authorizer can still use K and H_t , but cannot determine whether a current call continues an earlier external action-inducing source, thereby substantially weakening its ability to identify cross-step attacks.

PSG (Argument-Level Veto). Removing the final veto imposed by $A_t(c)$ increases both BU and UA on the two benchmarks, but also raises ASR to 2.49% and 2.73%, revealing a clear security–utility trade-off. This result shows that satisfying $G_t(c)$ and $C_t(c)$ alone is insufficient to guarantee that a call is authorized, because an attack call can preserve the overall task direction and execution chain while introducing localized authority expansion only through concrete argument bindings, such as recipients or target objects. PSG therefore enforces the authorization boundary at the actual argument level, at the cost that some legitimate calls with ambiguous authorization boundaries may also be rejected more conservatively.

AE (Positive Audited Evidence). Removing H_t does not increase ASR: it decreases from 0.06% and 0.17% to 0.00% and 0.12% on AgentDojo and AgentDyn, respectively. However, UA drops by approximately 10 and 13 percentage points, and BU on AgentDyn decreases from 56.03% to 49.17%. This result shows that the primary role of AE is not to further tighten the security boundary, but to provide an auditable legit-

imate execution source for runtime-generated dynamic values, such as file identifiers and object IDs. Without H_t , these dynamic bindings—which do not come directly from user input but are necessary for progressing open-ended tasks—have difficulty obtaining HISTORY_BOUND support, making authorization substantially more conservative. Thus, F_t preserves external action-inducing origins, whereas H_t provides positive support for legitimate runtime dependencies; together, they prevent persistent review from degenerating into indiscriminate rejection of dynamic execution.

NHP (Protection against Provenance Laundering). Removing NHP raises ASR to 0.65% and 0.75% on AgentDojo and AgentDyn, respectively, while BU and UA show no consistent change, consistent with its targeted role in handling specific provenance conflicts. NHP applies only when an argument value first appears as an action origin and later reappears in H_t , preventing this historical reappearance alone from promoting the value to HISTORY_BOUND support. Because such conflicts account for only a subset of runtime bindings, NHP has a much smaller impact on utility than PSG, while its security contribution lies in blocking the provenance-laundering path “action origin $\rightarrow$ historical reappearance $\rightarrow$ authority promotion.”

Overall, RQ3 shows that SARA’s security–utility balance arises from the asymmetric roles of these four mechanisms. AIT, PSG, and NHP primarily maintain the security boundary over action origins, argument bindings, and provenance conflicts, whereas AE establishes positive runtime evidence through audited successful executions, preventing these constraints from becoming overly restrictive. SARA’s complete authorization mechanism therefore does not rely on a single stricter criterion; instead, it jointly preserves “what external content induced” and “what legitimate execution has established,” and resolves potential provenance conflicts between them at the argument level.

5.4 RQ4: Security–Utility Gains and Additional Inference Cost

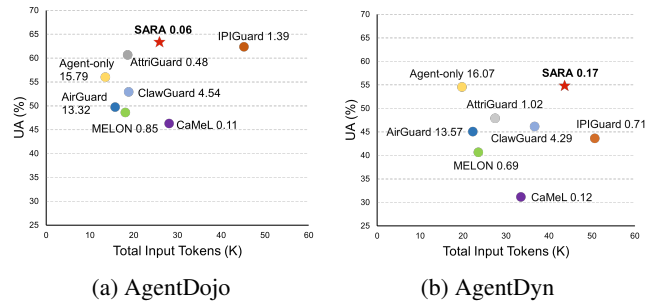


Figure 3: Security–utility–cost trade-off on AgentDojo and AgentDyn. Numbers beside methods denote ASR (%).

RQ4 further evaluates the runtime inference cost that

Table 4: Runtime inference cost on attack tasks across AgentDojo and AgentDyn.

Method	Agent		Guard		Total	
	Input	Calls	Input	Calls	Input	Output
AgentDojo						
Agent-only	13.54K	4.25	–	–	13.54K	0.28K
IPIGuard	36.91K	7.51	8.31K	1.99	45.22K	0.97K
CaMeL	27.70K	4.57	0.39K	0.80	28.10K	1.50K
MELON	9.62K	3.41	8.47K	5.13	18.09K	0.42K
AttriGuard	10.57K	4.21	8.32K	6.76	18.89K	1.38K
ClawGuard	15.73K	5.07	2.93K	2.45	18.65K	0.30K
AIRGuard	15.00K	4.38	0.77K	2.98	15.77K	0.48K
SARA	17.01K	4.87	8.85K	2.42	25.86K	0.93K
AgentDyn						
Agent-only	19.74K	5.55	–	–	19.74K	0.28K
IPIGuard	40.76K	8.08	9.90K	1.99	50.66K	1.03K
CaMeL	33.04K	5.14	0.39K	0.85	33.43K	1.63K
MELON	12.41K	4.01	11.14K	7.87	23.54K	0.45K
AttriGuard	20.83K	6.25	15.79K	9.76	36.62K	1.82K
ClawGuard	23.90K	6.98	3.55K	3.19	27.45K	0.32K
AIRGuard	21.51K	5.72	0.73K	2.95	22.24K	0.47K
SARA	25.75K	6.55	17.86K	4.91	43.61K	1.28K

SARA incurs to obtain the above security and utility gains, as well as the composition of that cost. Because end-to-end latency is readily affected by network conditions, model scheduling, and deployment configurations, we use average token consumption and API-call counts on GPT-4o-mini attack tasks as the primary cost metrics. Table 4 decomposes the cost between the Agent and Guard, while Figure 3 combines total input cost, UA, and ASR to show the security–utility–cost operating points of different defenses.

SARA is not the defense with the lowest token overhead, but its additional computational investment corresponds to a more competitive security–utility operating point. On AgentDojo, SARA’s average Agent and Guard inputs are 17.01K and 8.85K, respectively, for a total input of 25.86K, or $1.91\times$ that of Agent-only, corresponding to a UA of 63.44% and an ASR of 0.06%. Some methods have lower input costs but are generally accompanied by higher residual ASR or lower task utility. On the more dynamic AgentDyn, SARA’s total input increases to 43.61K, or $2.21\times$ that of Agent-only, corresponding to a UA of 54.92% and an ASR of 0.17%, only slightly higher than CaMeL’s 0.12% ASR. Thus, when the three objectives are lower total input cost, higher UA, and lower ASR, SARA forms a competitive non-dominated operating point on both benchmarks rather than obtaining security gains by pursuing the lowest token overhead.

SARA’s additional overhead arises primarily from two stages. The first is the **direct cost of authorization analysis**: SARA invokes its Guard components for authorization-root

construction, tool-effect classification, Observation probing, and execution-time authorization review, corresponding to Guard Input/Calls in the table. The second is the **indirect cost of trajectory adaptation**: SARA is responsible only for execution authorization and does not replace the main Agent’s planning; a rejected candidate call returns control to the Agent for replanning and therefore incurs additional Agent-side inference. Relative to Agent-only, SARA increases Agent Input/Calls from 13.54K/4.25 to 17.01K/4.87 on AgentDojo and from 19.74K/5.55 to 25.75K/6.55 on AgentDyn. Both Guard- and Agent-side costs are higher on AgentDyn, consistent with its greater dependence on runtime information: more dynamic objects and environmental feedback increase both the execution context required for authorization decisions and the planning burden of finding a legitimate path after rejection.

Overall, RQ4 shows that SARA’s security gains incur additional inference cost. On both benchmarks, SARA trades additional computation for very low ASR and high UA, indicating that its advantage lies in the system-level trade-off among security, task utility, and runtime cost rather than in minimizing computational overhead.

6 Conclusion and Limitations

This work introduces SARA, a runtime authorization mechanism designed to mitigate unauthorized tool execution caused by untrusted Observations while preserving support for legitimate runtime adaptation. SARA decouples *action induction* from *execution authorization*. Specifically, it persistently tracks the provenance of Observation-induced actions, re-evaluates authorization at the tool boundary based on user authorization and audited execution evidence, and prevents historical reappearance alone from promoting action-origin provenance into execution authority. Evaluations on AgentDojo and AgentDyn demonstrate that SARA limits the Attack Success Rate (ASR) to no more than 0.63% across the four primary evaluation settings, delivering consistent security gains across diverse Agent backbones.

These results come with two main limitations. First, SARA functions as a runtime authorization mechanism rather than a formal security guarantee. Its semantic judgments may yield false positives or false negatives, and recovering from blocked executions relies on the host Agent’s replanning capabilities, making overall utility dependent on model capability and workflow dynamics. Second, our empirical evaluation is restricted to tool-based Indirect Prompt Injection (IPI) workflows under the threat model defined in Section 2.2, which assumes trusted user inputs, tool schemas, the SARA runtime, and the underlying tool executor. Consequently, SARA does not address direct attacks bypassing the authorization runtime, pure data-dependency vulnerabilities, or unconditional control delegation to external sources.

References

- [1] Hengyu An, Jinghui Zhang, Tianyu Du, Chunyi Zhou, Qingming Li, Tao Lin, and Shouling Ji. IPIGuard: A novel tool dependency graph-based defense against indirect prompt injection in LLM agents. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing*, pages 1023–1039, Suzhou, China, November 2025. Association for Computational Linguistics. URL: <https://aclanthology.org/2025.emnlp-main.53/>, doi:10.18653/v1/2025.emnlp-main.53.
- [2] Khalid Belhajjame, Reza B’Far, James Cheney, Sam Coppens, Stephen Cresswell, Yolanda Gil, Paul Groth, Graham Klyne, Timothy Lebo, Jim McCusker, Simon Miles, James Myers, Satya Sahoo, and Curt Tilmes. Prov-dm: The prov data model. Project report, World Wide Web Consortium, April 2013. URL: <https://www.w3.org/TR/prov-dm/>.
- [3] Luca Beurer-Kellner, Beat Buesser, Ana-Maria Crețu, Edoardo Debenedetti, Daniel Dobos, Daniel Fabian, Marc Fischer, David Froelicher, Kathrin Grosse, Daniel Naeff, Ezinwanne Ozoani, Andrew Paverd, Florian Tramèr, and Václav Volhejn. Design patterns for securing llm agents against prompt injections, 2025. URL: <https://arxiv.org/abs/2506.08837>, arXiv:2506.08837.
- [4] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 2383–2400, Seattle, WA, August 2025. USENIX Association. URL: <https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe>.
- [5] Sizhe Chen, Arman Zharmagambetov, Saeed Mahlouljifar, Kamalika Chaudhuri, David Wagner, and Chuan Guo. Secalign: Defending against prompt injection with preference optimization. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, pages 2833–2847. Association for Computing Machinery, 2025. doi:10.1145/3719027.3744836.
- [6] Sarthak Choudhary, Divyam Anshumaan, Nils Palumbo, and Somesh Jha. How not to detect prompt injections with an LLM. In *Proceedings of the 18th ACM Workshop on Artificial Intelligence and Security, Taipei, Taiwan, October 13-17, 2025*, pages 218–229. ACM, 2025. doi:10.1145/3733799.3762980.
- [7] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025. URL: <https://arxiv.org/abs/2503.18813>.
- [8] Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, pages 82895–82920. Curran Associates, Inc., 2024. URL: <https://arxiv.org/abs/2406.13352>, doi:10.52202/079017-2636.
- [9] Dorothy E. Denning. A lattice model of secure information flow. *Commun. ACM*, 19(5):236–243, 1976. doi:10.1145/360051.360056.
- [10] William Enck, Peter Gilbert, Seungyeop Han, Vasant Tendulkar, Byung-Gon Chun, Landon P. Cox, Jaeyeon Jung, Patrick McDaniel, and Anmol N. Sheth. Taintdroid: An information-flow tracking system for realtime privacy monitoring on smartphones. *ACM Trans. Comput. Syst.*, 32(2), June 2014. doi:10.1145/2619091.
- [11] Linfeng Fan, Ziwei Li, Yuan Tian, Yichen Wang, Rongsheng Li, and Xiong Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the LLM reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. URL: <https://arxiv.org/abs/2605.11039>.
- [12] Google DeepMind. Gemini 2.5 Flash-Lite Model Card. Google DeepMind model card, September 2025. Model card published September 26, 2025; accessed: 2026-08-25. URL: <https://storage.googleapis.com/deepmind-media/Model-Cards/Gemini-2-5-Flash-Lite-Model-Card.pdf>.
- [13] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 2023 ACM Workshop on Artificial Intelligence and Security*, pages 79–90. Association for Computing Machinery, 2023. URL: <https://arxiv.org/abs/2302.12173>, doi:10.1145/3605764.3623985.
- [14] Norm Hardy. The confused deputy: (or why capabilities might have been invented). *SIGOPS Oper. Syst. Rev.*, 22(4):36–38, October 1988. doi:10.1145/54289.871709.
- [15] Yu He, Haozhe Zhu, Yiming Li, Shuo Shao, Hongwei Yao, Zhihao Liu, and Zhan Qin. AttrGuard: Defeating indirect prompt injection in LLM agents via

- causal attribution of tool invocations. *arXiv preprint arXiv:2603.10749*, 2026. URL: <https://arxiv.org/abs/2603.10749>.
- [16] Keegan Hines, Gary Lopez, Matthew Hall, Federico Zarfati, Yonatan Zunger, and Emre Kiciman. Defending against indirect prompt injection attacks with spotlighting. In *Proceedings of the Conference on Applied Machine Learning in Information Security (CAMLIS 2024)*, pages 48–62, 2024. URL: <https://ceur-ws.org/Vol-3920/paper03.pdf>.
- [17] Feiran Jia, Tong Wu, Xin Qin, and Anna Squicciarini. The task shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics*, pages 29680–29697, Vienna, Austria, July 2025. Association for Computational Linguistics. URL: <https://arxiv.org/abs/2412.16682>, doi:10.18653/v1/2025.acl-1.0ng.1435.
- [18] Maxwell Krohn, Alexander Yip, Micah Brodsky, Natan Cliffer, M. Frans Kaashoek, Eddie Kohler, and Robert Morris. Information flow control for standard os abstractions. In *Proceedings of Twenty-First ACM SIGOPS Symposium on Operating Systems Principles, SOSP ’07*, page 321–334, New York, NY, USA, 2007. Association for Computing Machinery. doi:10.1145/1294261.1294293.
- [19] Hao Li, Ruoyao Wen, Shanghao Shi, Ning Zhang, Yevgeniy Vorobeychik, and Chaowei Xiao. Agentdyn: Are your agent security defenses deployable in real-world dynamic environments? *arXiv preprint arXiv:2602.03117*, 2026. URL: <https://arxiv.org/abs/2602.03117>.
- [20] Minghao Li, Yingxiu Zhao, Bowen Yu, Feifan Song, Hangyu Li, Haiyang Yu, Zhoujun Li, Fei Huang, and Yongbin Li. API-bank: A comprehensive benchmark for tool-augmented LLMs. In Houda Bouamor, Juan Pino, and Kalika Bali, editors, *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*, pages 3102–3116, Singapore, December 2023. Association for Computational Linguistics. URL: <https://aclanthology.org/2023.emnlp-main.187/>, doi:10.18653/v1/2023.emnlp-main.187.
- [21] Xiao Liu, Hao Yu, Hanchen Zhang, Yifan Xu, Xuanyu Lei, Hanyu Lai, Yu Gu, Hangliang Ding, Kaiwen Men, Kejuan Yang, Shudan Zhang, Xiang Deng, Aohan Zeng, Zhengxiao Du, Chenhui Zhang, Sheng Shen, Tianjun Zhang, Yu Su, Huan Sun, Minlie Huang, Yuxiao Dong, and Jie Tang. Agentbench: Evaluating llms as agents. In *The Twelfth International Conference on Learning Representations*, 2024. URL: <https://openreview.net/forum?id=zAdUB0aCTQ>.
- [22] Yupei Liu, Yuqi Jia, Runpeng Geng, Jinyuan Jia, and Neil Zhenqiang Gong. Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 1831–1847, Philadelphia, PA, August 2024. USENIX Association. URL: <https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupei>.
- [23] Llama Team. The llama 3 herd of models. *arXiv preprint arXiv:2407.21783*, 2024. URL: <https://arxiv.org/abs/2407.21783>, arXiv:2407.21783.
- [24] Jiarui Lu, Thomas Holleis, Yizhe Zhang, Bernhard Aumayer, Feng Nan, Haoping Bai, Shuang Ma, Shen Ma, Mengyu Li, Guoli Yin, Zirui Wang, and Ruoming Pang. ToolSandbox: A stateful, conversational, interactive evaluation benchmark for LLM tool use capabilities. In Luis Chiruzzo, Alan Ritter, and Lu Wang, editors, *Findings of the Association for Computational Linguistics: NAACL 2025*, pages 1160–1183, Albuquerque, New Mexico, April 2025. Association for Computational Linguistics. URL: <https://aclanthology.org/2025.findings-naacl.65/>, doi:10.18653/v1/2025.findings-naacl.65.
- [25] Chang Ma, Junlei Zhang, Zhihao Zhu, Cheng Yang, Yujia Yang, Yaohui Jin, Zhenzhong Lan, Lingpeng Kong, and Junxian He. Agentboard: An analytical evaluation board of multi-turn llm agents. In A. Globerson, L. Mackey, D. Belgrave, A. Fan, U. Paquet, J. Tomczak, and C. Zhang, editors, *Advances in Neural Information Processing Systems*, volume 37, pages 74325–74362. Curran Associates, Inc., 2024. URL: https://proceedings.neurips.cc/paper_files/paper/2024/file/877b40688e330a0e2a3fc24084208dfa-Paper-Datasets_and_Benchmarks_Track.pdf, doi:10.52202/079017-2365.
- [26] Meta. Llama 3.3 70b instruct. Hugging Face model card, 2024. Official model card; accessed: 2026-08-25. URL: <https://huggingface.co/meta-llama/Llama-3.3-70B-Instruct>.
- [27] OpenAI. GPT-4o mini: Advancing Cost-Efficient Intelligence. OpenAI product announcement, July 2024. Accessed: 2026-08-25. URL: <https://openai.com/index/gpt-4o-mini-advancing-cost-efficient-intelligence/>.
- [28] Fábio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models, 2022. URL:

<https://arxiv.org/abs/2211.09527>, arXiv:2211.09527.

- [29] ProtectAI.com. Fine-tuned DeBERTa-v3-base for prompt injection detection. Hugging Face model card, 2024. Accessed: 2026-08-25. URL: <https://huggingface.co/ProtectAI/deberta-v3-base-prompt-injection-v2>.
- [30] Suliu Qin, Haomin Zhuang, Yujun Zhou, Yufei Han, and Xiangliang Zhang. AIRGuard: Guarding agent actions with runtime authority control. *arXiv preprint arXiv:2605.28914*, 2026. URL: <https://arxiv.org/abs/2605.28914>.
- [31] Yujia Qin, Shihao Liang, Yining Ye, Kunlun Zhu, Lan Yan, Yaxi Lu, Yankai Lin, Xin Cong, Xiangru Tang, Bill Qian, Sihan Zhao, Lauren Hong, Runchu Tian, Ruobing Xie, Jie Zhou, Mark Gerstein, dahai li, Zhiyuan Liu, and Maosong Sun. Toolllm: Facilitating large language models to master 16000+ real-world apis. In *The Twelfth International Conference on Learning Representations*, 2024. URL: <https://openreview.net/forum?id=dHng200Jjr>.
- [32] Qwen Team. Qwen2.5 technical report. *arXiv preprint arXiv:2412.15115*, 2024. URL: <https://arxiv.org/abs/2412.15115>, arXiv:2412.15115.
- [33] Qwen Team. Qwen3 technical report. *arXiv preprint arXiv:2505.09388*, 2025. URL: <https://arxiv.org/abs/2505.09388>, arXiv:2505.09388.
- [34] Vyas Raina, Adian Liusie, and Mark Gales. Is LLM-as-a-judge robust? investigating universal adversarial attacks on zero-shot LLM assessment. In Yaser Al-Onaizan, Mohit Bansal, and Yun-Nung Chen, editors, *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing*, pages 7499–7517, Miami, Florida, USA, November 2024. Association for Computational Linguistics. URL: <https://aclanthology.org/2024.emnlp-main.427/>, doi:10.18653/v1/2024.emnlp-main.427.
- [35] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an lm-emulated sandbox. In *The Twelfth International Conference on Learning Representations, ICLR 2024, Vienna, Austria, May 7-11, 2024*. OpenReview.net, 2024. URL: <https://openreview.net/forum?id=GEcwtMklUA>.
- [36] Andrei Sabelfeld and Andrew C. Myers. Language-based information-flow security. *IEEE J. Sel. Areas Commun.*, 21(1):5–19, 2003. doi:10.1109/JSAC.2002.806121.
- [37] J.H. Saltzer and M.D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975. doi:10.1109/PROC.1975.9939.
- [38] Timo Schick, Jane Dwivedi-Yu, Roberto Dessi, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. In A. Oh, T. Naumann, A. Globerson, K. Saenko, M. Hardt, and S. Levine, editors, *Advances in Neural Information Processing Systems*, volume 36, pages 68539–68551. Curran Associates, Inc., 2023. URL: https://proceedings.neurips.cc/paper_files/paper/2023/file/d842425e4bf79ba039352da0f658a906-Paper-Conference.pdf, doi:10.52202/075280-2997.
- [39] Sander Schulhoff. The sandwich defense: Strengthening ai prompt security. Learn Prompting, 2024. Last updated October 23, 2024. URL: https://learnprompting.org/docs/prompt_hacking/defensive_measures/sandwich_defense.
- [40] Jiawen Shi, Zenghui Yuan, Yinuo Liu, Yue Huang, Pan Zhou, Lichao Sun, and Neil Zhenqiang Gong. Optimization-based prompt injection attack to llm-as-a-judge. In Bo Luo, Xiaojing Liao, Jun Xu, Engin Kirda, and David Lie, editors, *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security, CCS 2024, Salt Lake City, UT, USA, October 14-18, 2024*, pages 660–674. ACM, 2024. doi:10.1145/3658644.3690291.
- [41] Eric Wallace, Kai Xiao, Reimar Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The instruction hierarchy: Training llms to prioritize privileged instructions, 2024. URL: <https://arxiv.org/abs/2404.13208>, arXiv:2404.13208.
- [42] Lei Wang, Chen Ma, Xueyang Feng, Zeyu Zhang, Hao Yang, Jingsen Zhang, Zhiyuan Chen, Jiakai Tang, Xu Chen, Yankai Lin, Wayne Xin Zhao, Zhewei Wei, and Jirong Wen. A survey on large language model based autonomous agents. *Frontiers of Computer Science*, 18(6), March 2024. URL: <http://dx.doi.org/10.1007/s11704-024-40231-1>, doi:10.1007/s11704-024-40231-1.
- [43] Peiran Wang, Ying Li, and Yuan Tian. Aligning provenance with authorization: A dual-graph defense for LLM agents. *arXiv preprint arXiv:2605.26497*, 2026. URL: <https://arxiv.org/abs/2605.26497>.
- [44] Tianbao Xie, Danyang Zhang, Jixuan Chen, Xiaochuan Li, Siheng Zhao, Ruisheng Cao, Toh Jing Hua, Zhoujun Cheng, Dongchan Shin, Fangyu Lei, Yitao Liu, Yiheng

- Xu, Shuyan Zhou, Silvio Savarese, Caiming Xiong, Victor Zhong, and Tao Yu. Osworld: Benchmarking multimodal agents for open-ended tasks in real computer environments. In A. Globerson, L. Mackey, D. Belgrave, A. Fan, U. Paquet, J. Tomczak, and C. Zhang, editors, *Advances in Neural Information Processing Systems*, volume 37, pages 52040–52094. Curran Associates, Inc., 2024. URL: https://proceedings.neurips.cc/paper_files/paper/2024/file/5d413e48f84dc61244b6be550f1cd8f5-Paper-Datasets_and_Benchmarks_Track.pdf, doi:10.52202/079017-1650.
- [45] Shunyu Yao, Noah Shinn, Pedram Razavi, and Karthik Narasimhan. τ -bench: A benchmark for tool-agent-user interaction in real-world domains. In *The Thirteenth International Conference on Learning Representations*, 2025. URL: <https://openreview.net/forum?id=roNSXZpUDN>.
- [46] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. React: Synergizing reasoning and acting in language models. In *The Eleventh International Conference on Learning Representations*, 2023. URL: https://openreview.net/forum?id=WE_vluYUL-X.
- [47] Junjie Ye, Sixian Li, Guanyu Li, Songyang Gao, Yilong Wu, Qi Zhang, Tao Gui, and Xuanjing Huang. ToolSword: Unveiling safety issues of large language models in tool learning across three stages. In Lun-Wei Ku, Andre Martins, and Vivek Srikumar, editors, *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 2181–2211, Bangkok, Thailand, August 2024. Association for Computational Linguistics. URL: <https://aclanthology.org/2024.acl-long.119/>, doi:10.18653/v1/2024.acl-long.119.
- [48] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. Injecagent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506, Bangkok, Thailand, August 2024. Association for Computational Linguistics. URL: <https://arxiv.org/abs/2403.02691>, doi:10.18653/v1/2024.findings-acl.624.
- [49] Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent security bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents. In *The Thirteenth International Conference on Learning Representations*, 2025. URL: <https://openreview.net/forum?id=V4y0CpX4hK>.
- [50] Wei Zhao, Zhe Li, Peixin Zhang, and Jun Sun. ClawGuard: A runtime security framework for tool-augmented LLM agents against indirect prompt injection. *arXiv preprint arXiv:2604.11790*, 2026. URL: <https://arxiv.org/abs/2604.11790>.
- [51] Peter Yong Zhong, Siyuan Chen, Ruiqi Wang, McKenna McCall, Ben L. Titzer, Heather Miller, and Phillip B. Gibbons. RTBAS: defending LLM agents against prompt injection and privacy leakage. *CoRR*, abs/2502.08966, 2025. URL: <https://doi.org/10.48550/arXiv.2502.08966>, arXiv:2502.08966, doi:10.48550/ARXIV.2502.08966.
- [52] Shuyan Zhou, Frank F. Xu, Hao Zhu, Xuhui Zhou, Robert Lo, Abishek Sridhar, Xianyi Cheng, Tianyue Ou, Yonatan Bisk, Daniel Fried, Uri Alon, and Graham Neubig. Webarena: A realistic web environment for building autonomous agents. In *The Twelfth International Conference on Learning Representations*, 2024. URL: <https://openreview.net/forum?id=oKn9c6ytLx>.
- [53] Kaijie Zhu, Xianjun Yang, Jindong Wang, Wenbo Guo, and William Yang Wang. MELON: Provable defense against indirect prompt injection attacks in AI agents. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 80310–80329. PMLR, 2025. URL: <https://proceedings.mlr.press/v267/zhu25z.html>.